

Eng 5.2. Logging for Accountability

Task 1 - Introduction

Logging is used to provide a "source of truth" for activity that occurs on a network. Logging is most commonly used, but not limited to incident response and security monitoring. During the incident response process, a user may be held accountable for an action or behavior, and logging plays a crucial role in proving a user's actions. Accountability is the final pillar of the Identification, Authentication, Authorization, and Accountability (IAAA) model. The model is used to protect and maintain confidentiality, integrity, and availability of information.

Accountability holds users and peers on a network responsible for their actions. Logging is a large part of this pillar and maintains a record of activities. To ensure the efficacy of accountability, logs and other data sources must be protected, and their authenticity must be proved. If it cannot be proven that a log was kept in its original state, it loses its integrity for accountability and the incident response process.

Task 2 - Importance of Logging and Data Aggregation

Logging aids any member involved in the incident response process. Depending on the log source, it may provide different benefits or visibility into a network or device. Some examples may include:

- Files created.
- Emails sent.
- Other TTPs (Tactics, Techniques, and Procedures) as outlined by the MITRE ATT&CK framework

Because logs play an important role in incident response, they must be authentic and, when analyzed, identical to when they were produced. Adding accountability to the incident response process, when log sources are guaranteed to be authentic, a user can be held accountable for their actions, as proven by logs.

This use of accountability is more formally known as non-repudiation and contributes to many threat models, such as the [STRIDE model\(opens in new tab\)](#). Non-repudiation means that an individual cannot contest an action, the opposite of repudiation, where an individual disputes an action.

Security Information and Event Management

A **Security Information and Event Management** system (**SIEM**) is a tool used to collect, index, and search data from various endpoints and network locations. While this room won't cover in-depth log analysis and SIEMs, it is important to create a basic level of understanding. We will leverage an SIEM in later tasks to get hands-on with the concepts presented in this room.

SIEMs have many features and capabilities, often for specific use cases. Below is a summary of the benefits and features that an SIEM can offer at the most basic level:

- Real-time log ingestion.
- Alerting against abnormal activities.
- 24/7 monitoring and visibility.
- Data insights and visualization.
- Ability to investigate past incidents.

Examples of SIEMs may include Wazuh, Splunk, ELK, and QRadar. For more information, check out [Auditing and Monitoring](#).

Answer the questions below

A user being held accountable for their actions, as proven by logs, is known as what?

non-repudiation

Task 3 - Log Ingestion and Storage

SIEMs are typically architected with three components used for searching, indexing, and load-balancing; these components are commonly known as the **search head**, **indexer**, and **forwarder**, respectively. In this room, our objective is accountability, so we will focus primarily on the indexer and how data

arrives from a device to the indexer; this process is commonly known as **data ingestion**.

- Types of data ingestion
 - Agent/forwarder
 - Port-forwarding
 - Syslog
 - Upload

While there are several ways of ingesting data, there tend to be fewer ways to store the data. Although the primary point of failure for accountability is ingestion, storage can be equally challenging. When dealing with storage concerns, it is often not attackers we must worry about, but technical faults; for example, an index is accidentally deleted, or a storage device is corrupted.

These are a few examples of things to consider when architecting a storage solution for log sources. While keeping this data authentic and secure is important for accountability, it often has overlapping themes with compliance. Compliance and regulations go hand in hand; one such regulation may be that log data must be archived or stored for X amount of time. This plays into accountability again, where non-repudiation must be applied to a log source for compliance. For example, an audit requires the past six months of X log source. As a stakeholder, you must guarantee that those log sources reflect the activity of the network.

One solution to the storage problem is cold storage. Cold storage is a process or standard for storing data, which can be summarized as storing a large quantity of data optimally.

Cold storage is rarely accessed and thus does not require high-performance storage devices. Examples of cold storage may include low-cost hard drives or even tape drives! Conversely, hot storage is data accessed often and requires higher performance, which may consist of solid-state drives and, in some cases, high-performance hard drives. There may be other levels of access and performance throughout the life cycle of data that can be referred to as warm storage. The standard for how long data stays in each phase will depend on regulatory requirements and company guidelines. An example of a storage process may be that data is stored hot for six months, warm for three months, and

cold for three years. Depending on the data, it may be indefinitely stored in cold storage.

Payment Card Industry Data Security Standard (PCI DSS) is one example of a standard that requires audit logs to be stored for a year and kept immediately available for 90 days to remain compliant.

Answer the questions below

| What component of an SIEM is responsible for searching data?

search head

| How many years must all audit data be stored to be PCI DSS compliant?

1

Task 4 - Types of Logs and Data Sources

Now that some problems are solved with how data will be sent to an indexer and SIEM solution, we must consider - what makes a good log. While an SIEM provides excellent functionality, its purpose is to ingest any data and provide an effective and easy way to index and search it. If a log does not give you the information required for an investigation, it cannot be used for accountability and does not uphold non-repudiation. Many log sources exist to collect data efficiently with as much relevant information as possible. In this task, we will outline a few of the most common log sources and how they may be used in the incident response process.

- Manual log sources
 - Any log that is manually written or composed by an author
 - Change logs
- Automated log sources
 - Any logs that are automatically generated by default, for example, a configuration, tool, or from a developer
 - System logs
 - Application logs

- Other types of logs
 - Some logs may not be categorized but are often required for compliance
 - Email logs
 - Messaging or other communication

A good log source may not include only one log. Due to the nature of a network, it may require multiple log types to create one quality log source, for example, a firewall log and a system log used together to hold each other accountable. That is, the validity of one log can be proven using another and vice-versa. A log source could also be collecting too much information; that is, if several types of logs are collecting the same data or creating the same alerts, it can increase noise, storage complexity, and other consequences.

Answer the questions below

| A change log is an example of what log source?

Manual

| An application log is an example of what log source?

Automated

Task 5 - Using Logs Effectively

There are many types of SIEMs to choose from, and each feature and capability can impact how you can use logs effectively. If you are not using a specific feature of an SIEM, it does not signify that you are not effectively using logs, as it depends on log sources and usage requirements. For example, if you are only using logs as an incident response tool and not for real-time monitoring, you may not need or use the real-time feature of some SIEMs.

As briefly introduced in task four, using multiple log types and sources is beneficial for validating logs and creating a complete story of an incident. This concept is more formally known as **correlation** or building a relationship between two things: logs and data. For example, if a user performed a suspicious action (created a DLL file on the disk), a browser application log could be used to correlate their browser search history with their behavior. If they were searching

Answer the questions below

correlation

We have provided web application access to a commonly used SIEM, Splunk. A dataset that contains all the information you need to answer the upcoming questions has already been loaded for you. In this exercise, we are looking to practice the correlation of log sources and prove accountability's efficacy. To access the terminal, deploy the lab machine attached to this task by pressing the green **Start Lab Machine** button. Please allow the machine 3 - 5 minutes to deploy.

How many total events are indexed by Splunk?

12,256

Eng 5.2. Logging for Accountability

How many events were indexed from April 15th to 16th 2022?

12,250

The screenshot shows the Splunk Enterprise Search interface. The search bar contains 'Index=*' and the date range is set to 'from Apr 15 through Apr 16, 2022'. The search results show 12,250 events. A sample event is displayed in the table view:

Time	Event
15/04/2022 08:06:48.000	<pre>{ "version": 1, "category": "Pipeline Execution Details", "channel": "Windows PowerShell", "eventid": 800, "eventreceivedtime": "2022-04-15 08:06:49" }</pre>

How many unique users appear in the data set?

4

splunk>enterprise Apps ▾

Search Analytics Datasets Reports Alerts Dashboards

New Search

1 index=*

✓ 12,250 events (15/04/2022 00:00:00.000 to 17/04/2022 00:00:00.000) No Event Sampling ▾

Events (12,250) Patterns Statistics Visualization

Format Timeline ▾ - Zoom Out + Zoom to Selection × Deselect

< Hide Fields All Fields

SELECTED FIELDS

- a host 1
- a source 1
- a sourcetype 1
- a User 4

INTERESTING FIELDS

- # @version 1
- a AccountName 4
- a AccountType 2
- a Application 22
- a Category 41
- a Channel 9

User

4 Values, 0.971% of events

Selected

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
NT AUTHORITY\SYSTEM	70	58.824%
Cybertees\Alberto	24	20.168%
NT AUTHORITY\NETWORK SERVICE	20	16.807%
Cybertees\James	5	4.202%

How many events are associated with the user "James"?

5

What utility was used in the oldest event associated with "James"?

wmic

```

> 15/04/2022 08:06:01.000 {"EventID":1,"RecordNumber":423322,"ProviderGuid":{"5770385F-C22A-43E0-BF4C-06F5698FFBD9"},"SourceName":"Microsoft-Windows-Log","ExecutionProcessID":3524,"AccountType":"User","Category":"Process Create (rule: ProcessCreate)","Domain":"NT AUTHORITY\SYSTEM","ParentProcessID":9564,"ThreadID":4688,"CurrentDirectory":"C:\\windows\\system32\\","Severity":"INFO","IntegrityLevel":"System","tags":["splunk"],"EventTime":"2022-04-15 08:06:01","CommandLine":"C:\\windows\\system32\\wbem\\WMIC.exe /n","host":"cybertees.net","SeverityValue":2,"Message":"Process Create:\\r\\nRuleName: -\\r\\nUtcTime: 2022-04-15 12:06:01.878\\r\\nImage: C:\\Windows\\System32\\wbem\\WMIC.exe\\r\\nFileVersion: 10.0.18362.1 (WinBuild.160101.0800)\\r\\nDescription: WMI company: Microsoft Corporation\\r\\nOriginalFileName: wmic.exe\\r\\nCommandLine: \\\"C:\\windows\\System32\\wbem\\WMIC.exe\\\" /nCurrentDirectory: C:\\windows\\system32\\r\\nUser: Cybertees\\James\\r\\nLogonGuid: {2d351099-5053-5f5f-13c0-2c0000000000}\\r\\n"}

```

What event ID followed process creation events associated with "James"?

splunk>enterprise Apps ▾

Search Analytics Datasets Reports Alerts Dashboards

New Search

1 index=* User="Cybertees\\James" EventID=3

✓ 1 event (15/04/2022 00:00:00.000 to 17/04/2022 00:00:00.000) No Event Sampling ▾

Events (1) Patterns Statistics Visualization

Format Timeline ▾ — Zoom Out + Zoom to Selection × Deselect

List ▾ ↗ Format 50 Per Page ▾

< Hide Fields	≡ All Fields	i	Time	Event
SELECTED FIELDS a host 1 a source 1 a sourcetype 1 a User 1 INTERESTING FIELDS # @version 1 a AccountName 1		>	15/04/2022 08:06:02.000	<pre>{ [-] @version: 1 AccountName: SYSTEM AccountType: User Category: Network connection detected (rule: NetworkConnect) Channel: Microsoft-Windows-Sysmon/Operational DestinationHostname: - DestinationIp: 172.18.39.6 DestinationIsIpv6: false DestinationPort: 61249</pre>